



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://localhost:3000>

Generated on Thu, 4 Jun 2026 07:36:10

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	1
Informational	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	3
Low	Warning		ZAP warnings logged - see the zap. log file for details	6
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	28 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 4xx	71 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	100 %
			Percentage of	

Info	Informational	http://localhost:3000	endpoints with method GET	100 %
Info	Informational	http://localhost:3000	Count of total endpoints	2

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	2
CSP: Wildcard Directive	Medium	1
CSP: Notices	Low	1

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing /excluding them is the same as allowing anything.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	default-src 'self';script-src 'self' 'trusted-cdn.com';style-src 'self' 'fonts.googleapis.com';img-src 'self' data:;connect-src 'self';upgrade-insecure-requests;base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';object-src 'none';script-src-attr 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: font-src
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	CSP: Notices
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	default-src 'self';script-src 'self' 'trusted-cdn.com';style-src 'self' 'fonts.googleapis.com';img-src 'self' data:;connect-src 'self';upgrade-insecure-requests;base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';object-src 'none';script-src-attr 'none'
Other Info	Errors: Unrecognized source-expression 'trusted-cdn.com' Unrecognized source-expression 'fonts.googleapis.com'
Instances	1

Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055